

АЛЬФА БУДУЩЕЕ

Альфа Банк

Правила

Задания

Рейтинг

team_whatever

3063 балла

Ред-флаг

Автор: @b1n4r9, SPbCTF

Решило 111 команд

Medium

Ctf

Linux

Logic

Решено

Как понять суть g0rgs0rg? Конечно, расставить ред-флаги на всё, что к нему не относится! Скорее присоединяйтесь к нашему тир-листу.

```
ssh [REDACTED]
Username: [REDACTED]
Password: [REDACTED]
```

Исходники: [redflag.sh](https://github.com/redflag-sh)

Введите сюда ответ

Сдать флаг

Задание с Альфа CTF - infra, medium

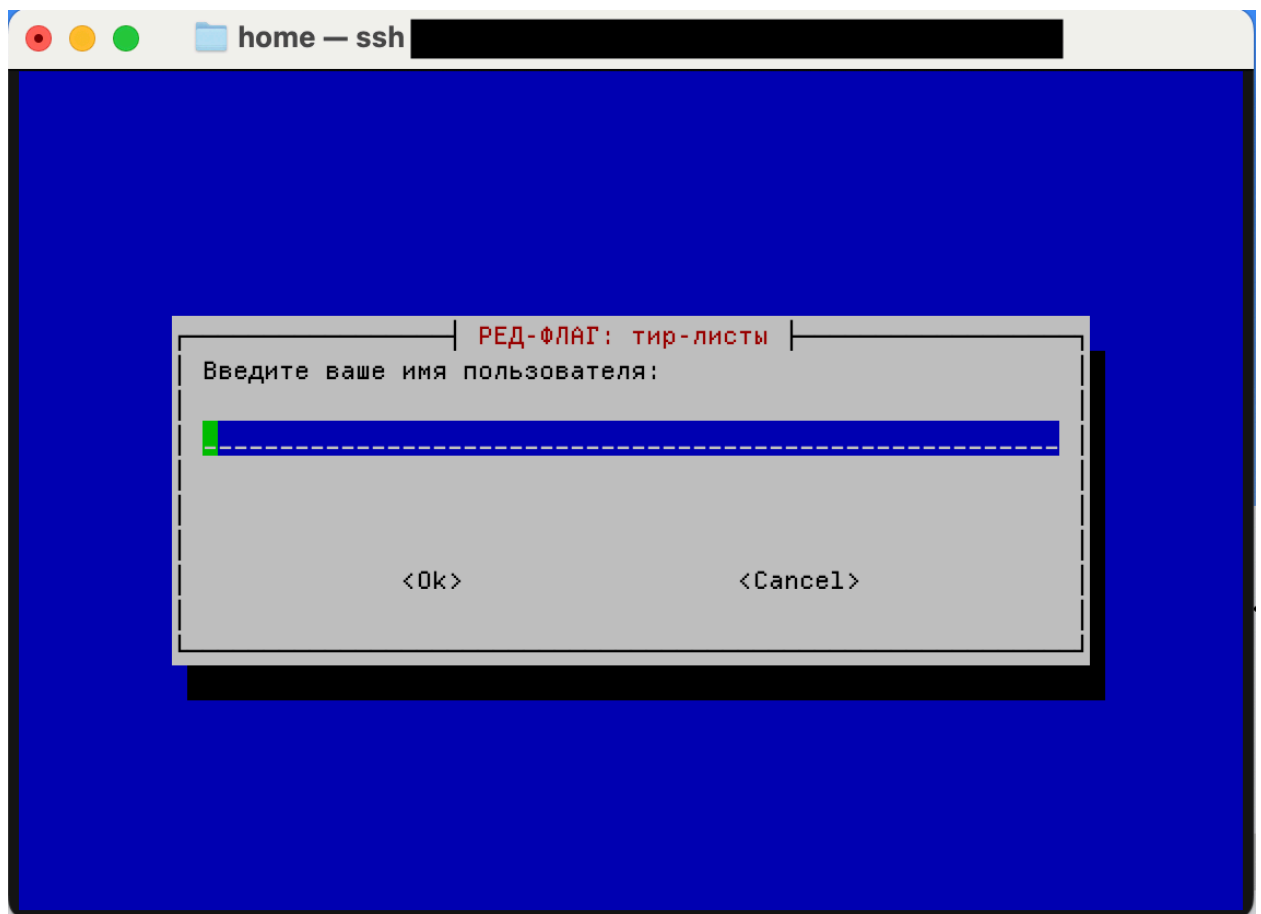
Из данного – ssh подключение к серверу и исходник .sh, то есть предположительно – bash скрипт. Задание звучит странно, возможно во фразе «расставить ред-флаги на всё, что к нему не относиться» может быть подсказкой. Просмотрим файл. В нем действительно большой bash скрипт на ~600 строк. Его содержание приложу в файле (название скрипта в моем файле – red_flag.sh)

Краткое описание – этот скрипт создает интерактивную систему управления тир-листами в консоли. Главной уязвимой механикой в этом скрипте является механика соавторства, а точнее join tier list и leave tier list

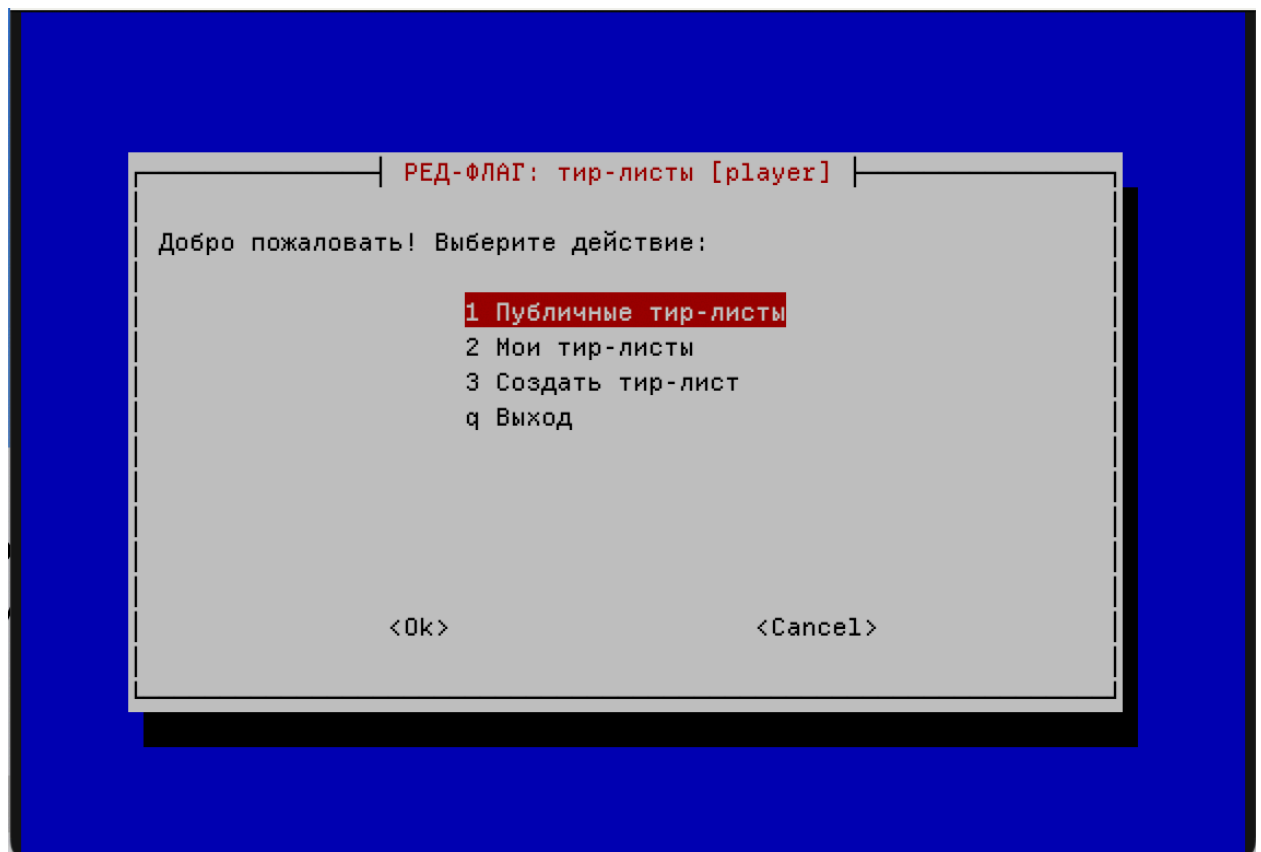
Итак, заходим на сервер

```
[home@MacBookPro ~] % ssh [REDACTED]
The authenticity of host '[REDACTED]' can't be established.
ED25519 key fingerprint is SHA256:[REDACTED]
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[REDACTED]' to the list of known hosts.
[REDACTED] password:
```

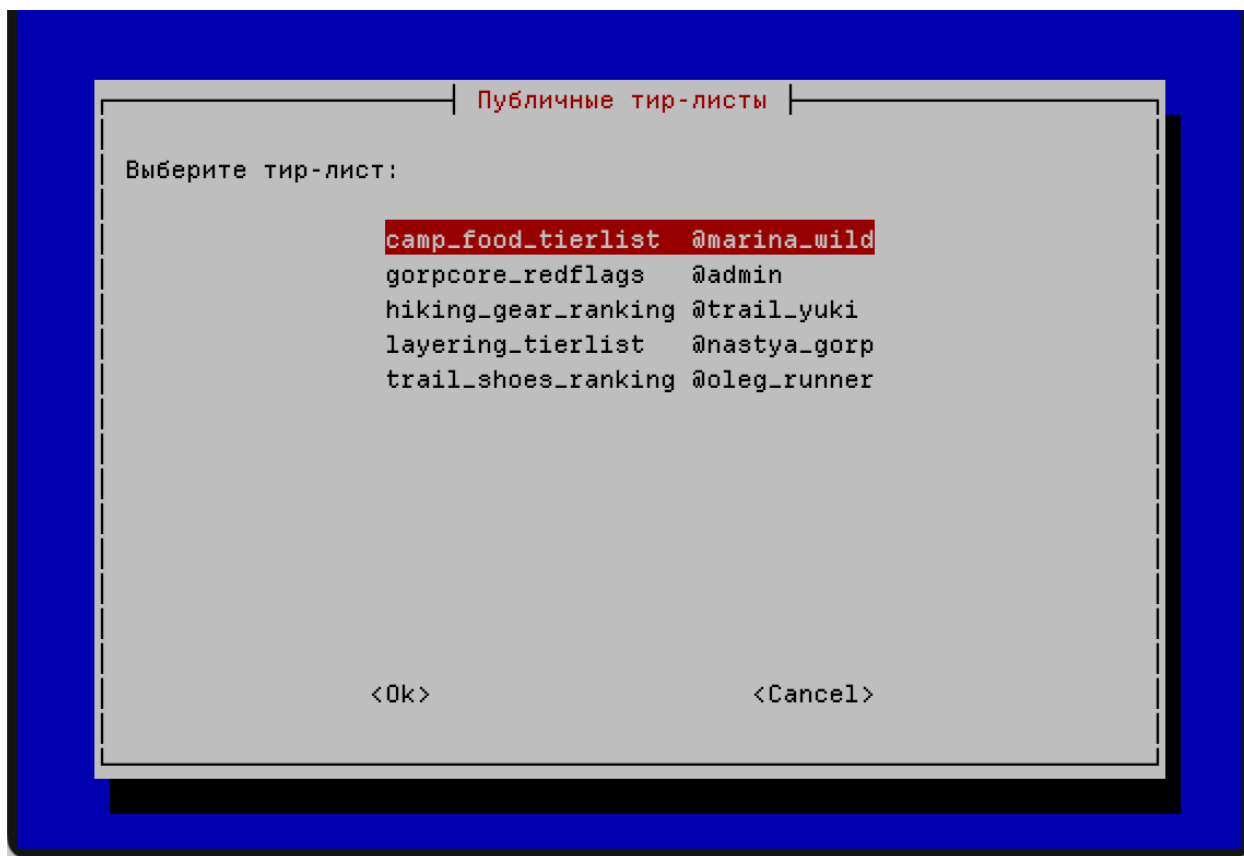
После захода на сервер нас встречает та самая интерактивная система, предлагающая войти, введя имя пользователя



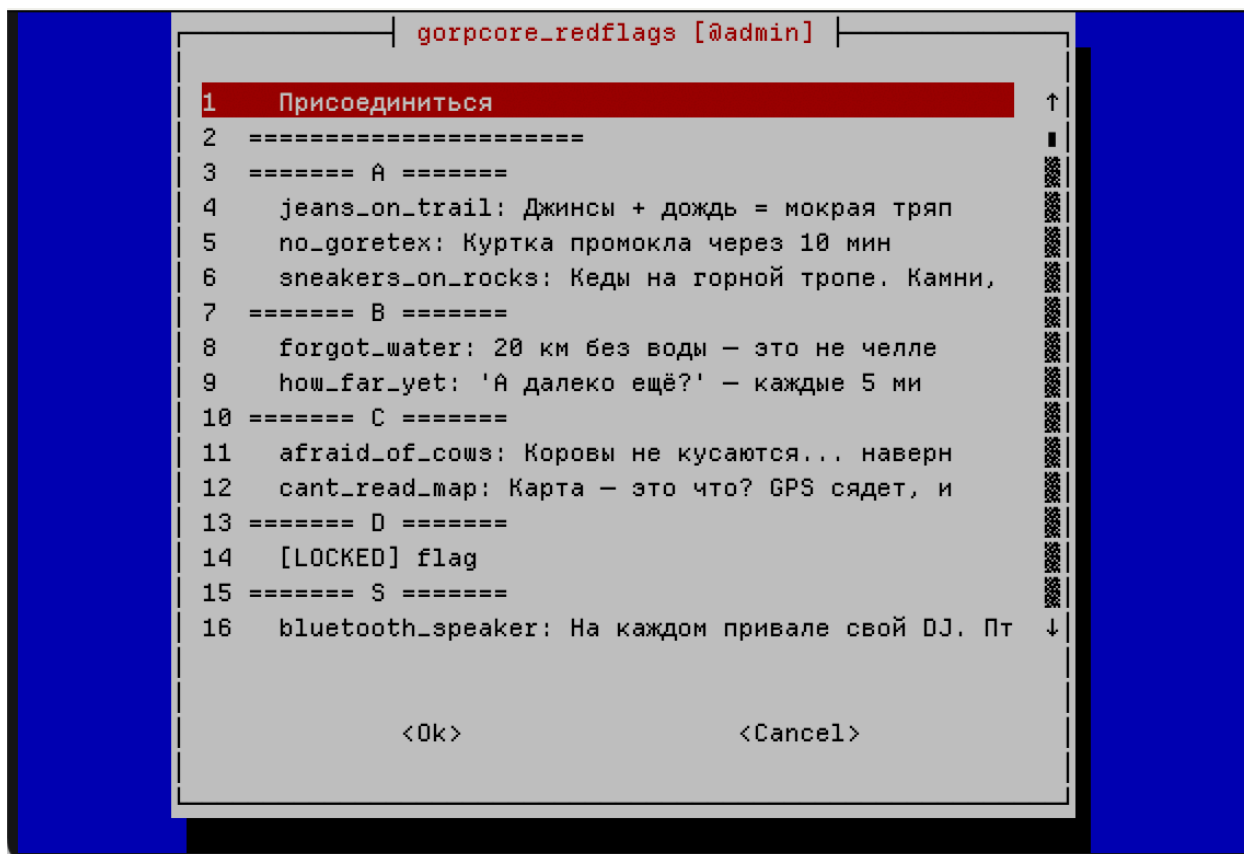
Имя я выбрал – player, после входа мы видим следующую страницу



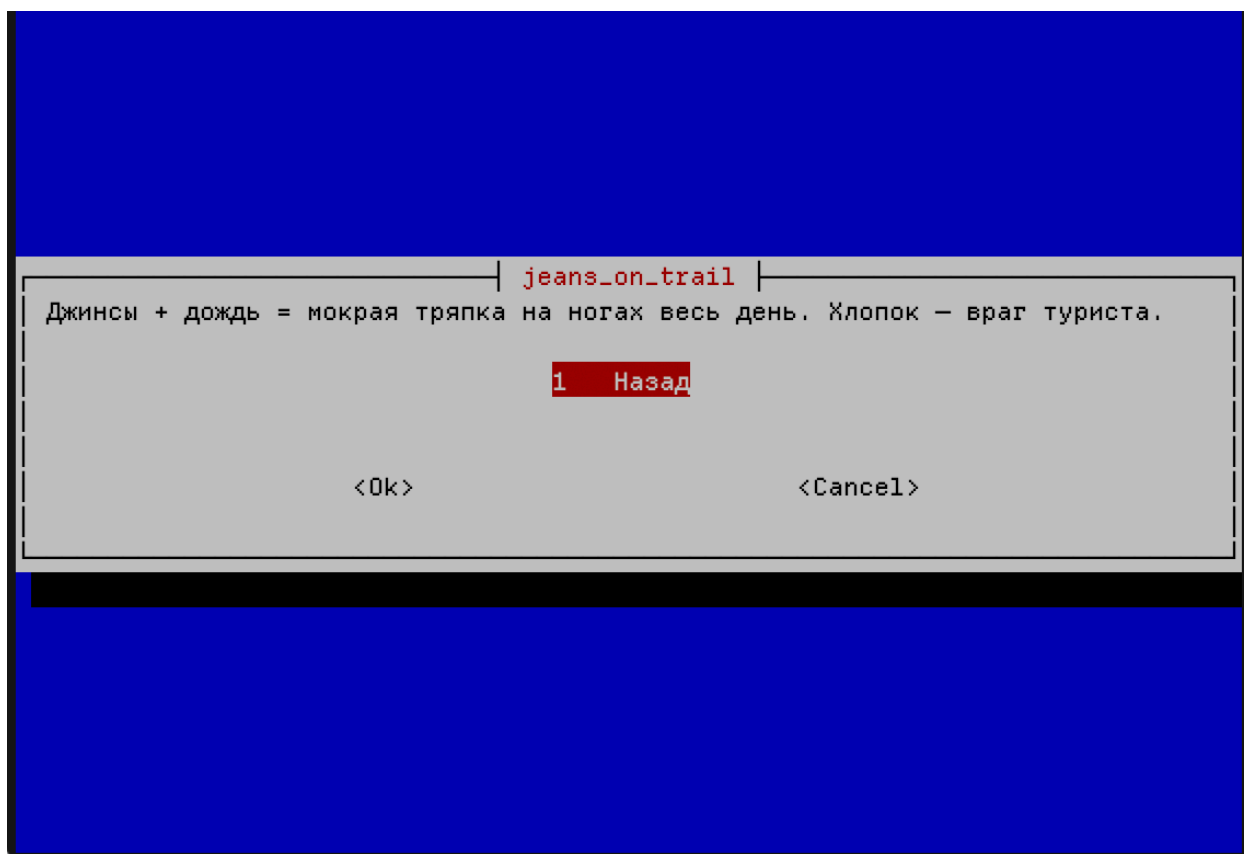
Мы можем просмотреть публичные тир листы, посмотреть свои, создать новый и выйти.
Посмотрим публичные листы



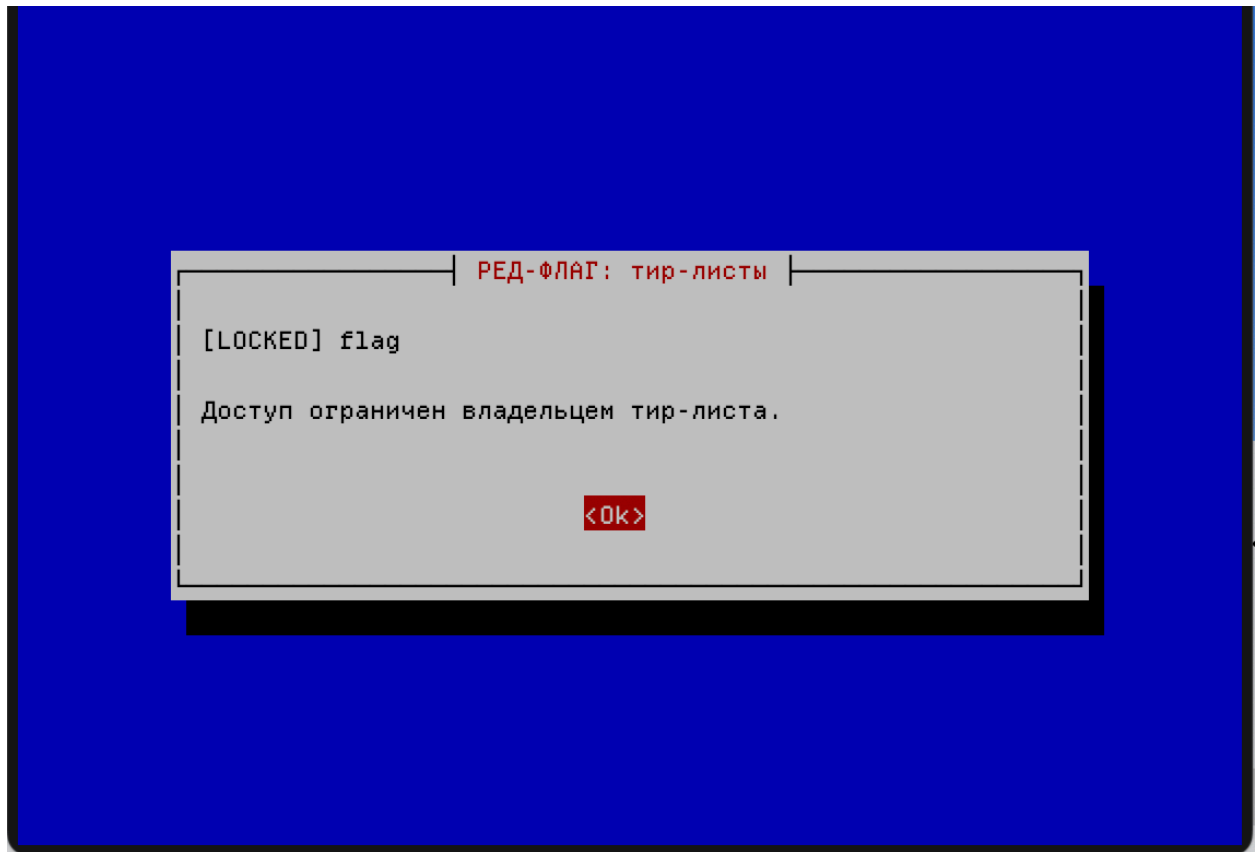
Всего их 5 (важный момент, в скрипте прописано, что есть 5 зарезервированных имен пользователей, которые нельзя создать нам). Зайдем в самый интересующий нас лист от пользователя admin



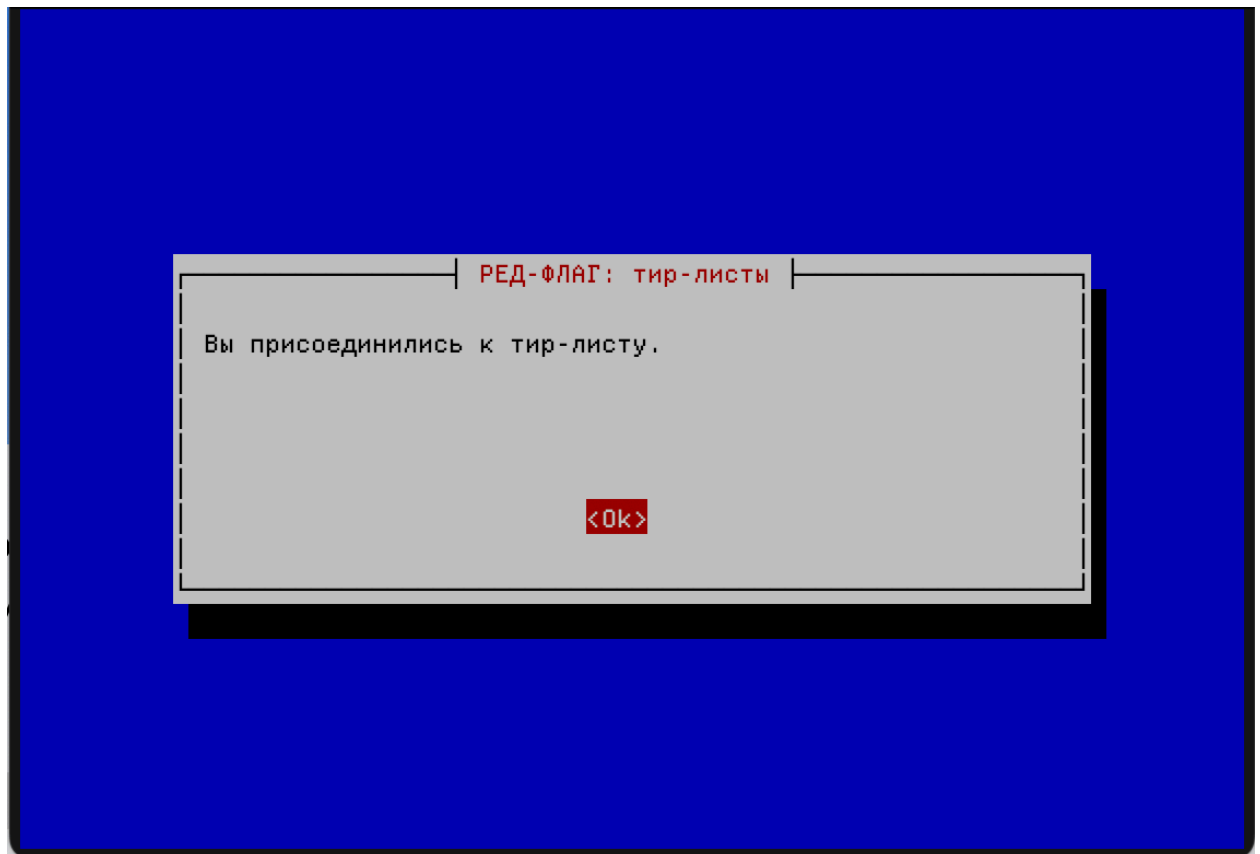
Тут мы видим не совсем понятные данные, строки текста на разные тематики и возможность присоединиться к листу. Лично я посчитал, что эти тирлисты – тирлисты фраз. Также мы можем в строке 14 увидеть надпись [LOCKED] flag. Для начала нажмем на случайный тир и посмотрим что будет



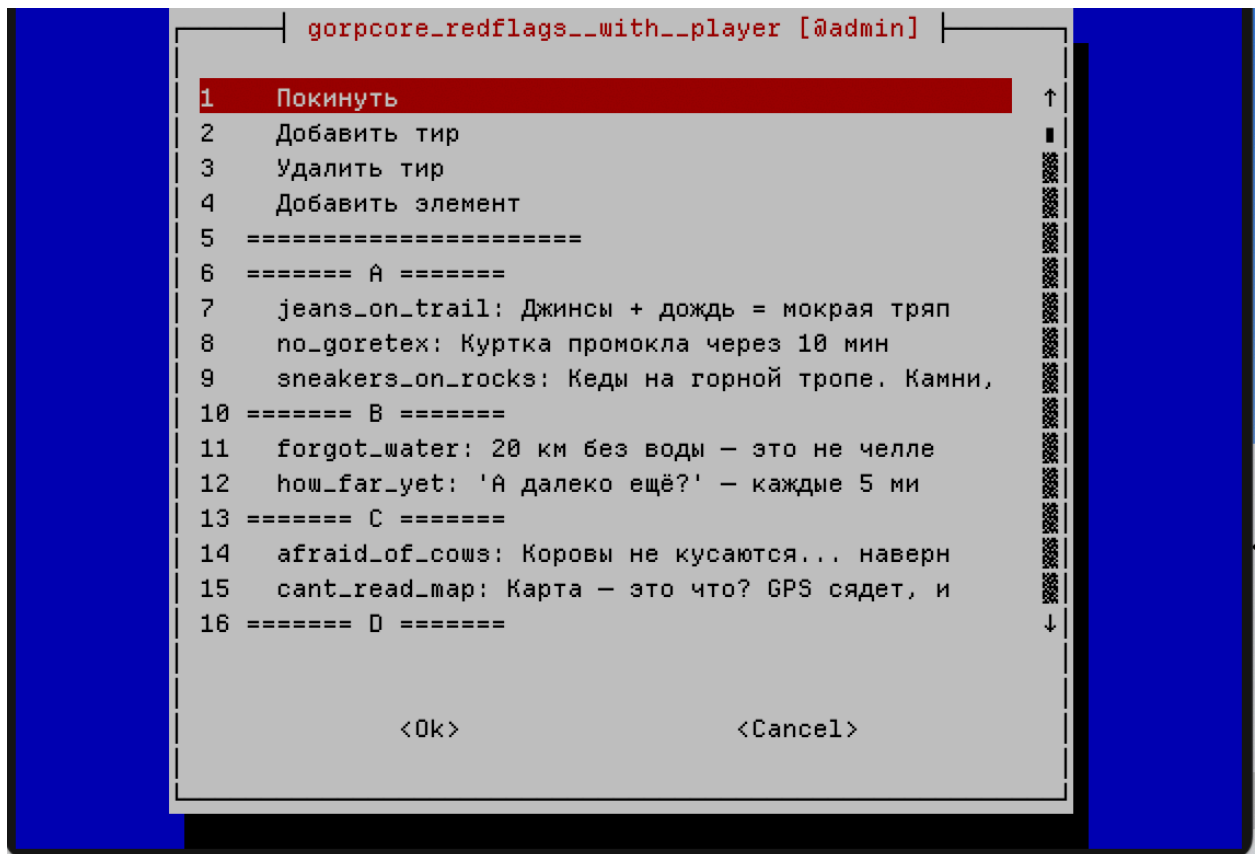
При нажатии – просто просмотр текста. Попробуем нажать на locked flag.



Доступ ограничен, логично. Теперь попробуем присоединиться к листу



После этого при просмотре листа у нас появляются доп функции



Можно покинуть лист, добавить тир, удалить тир и добавить элемент. Как мной было сказано ранее, уязвимости в скрипте были связаны с `leave` и `join` тирлиста. При входе и выходе из него у листа меняется название на «староназвание__with__твой_ник», то есть присоединившись к `admin` название превратилось в `gorpcore_redflags__with__player`. Моя теория – создать свой тирлист со СТАРЫМ названием листа админа, то есть `gorpcore_redflags`. Потом выйти из листа админа, его лист переименуется назад в `gorpcore_redflags` и из-за того, что нет проверки на существование тирлиста с таким же именем после `leave`. Вот части кода:

```
join_tierlist_by_name() {  
    local tl_name="$1"  
    local new_name="${tl_name}__with__$${CURRENT_USER}"  
    mv "$TIERLISTS_DIR/$tl_name" "$TIERLISTS_DIR/$new_name" # (1)  
    local collabs  
    collabs=$(meta_get "$TIERLISTS_DIR/$new_name" "collaborators") || collabs=""  
    if [[ -z "$collabs" ]]; then  
        meta_set "$TIERLISTS_DIR/$new_name" "collaborators" "$CURRENT_USER"  
    else  
        meta_set "$TIERLISTS_DIR/$new_name" "collaborators" "${collabs},${CURRENT_USER}"  
    fi  
}
```

```

fi

msg "Вы присоединились к тир-листу."
}

leave_tierlist_by_name() {
    local tl_name="$1"
    local original="${tl_name%__with__${CURRENT_USER}}" # (2)
    if [[ "$original" != "$tl_name" ]]; then
        mv "$TIERLISTS_DIR/$tl_name" "$TIERLISTS_DIR/$original" # (3)
    fi
}

```

Рассмотрим поточнее leave функцию –

Здесь mv перемещает каталог (например, gorpcore_redflags__with__player) обратно в gorpcore_redflags.

Но нет никакой проверки, что каталог gorpcore_redflags уже не существует.

Если между join и leave кто-то создал новый каталог с именем gorpcore_redflags, то mv не выдаст ошибку, а переместит исходный каталог внутрь существующего – потому что таково поведение mv в Linux: при перемещении каталога в уже существующий каталог первый становится подкаталогом второго.

Теперь проверим все это, создаем лист, выходим из предыдущего и смотрим что выйдет

РЕД-ФЛАГ: тир-листы

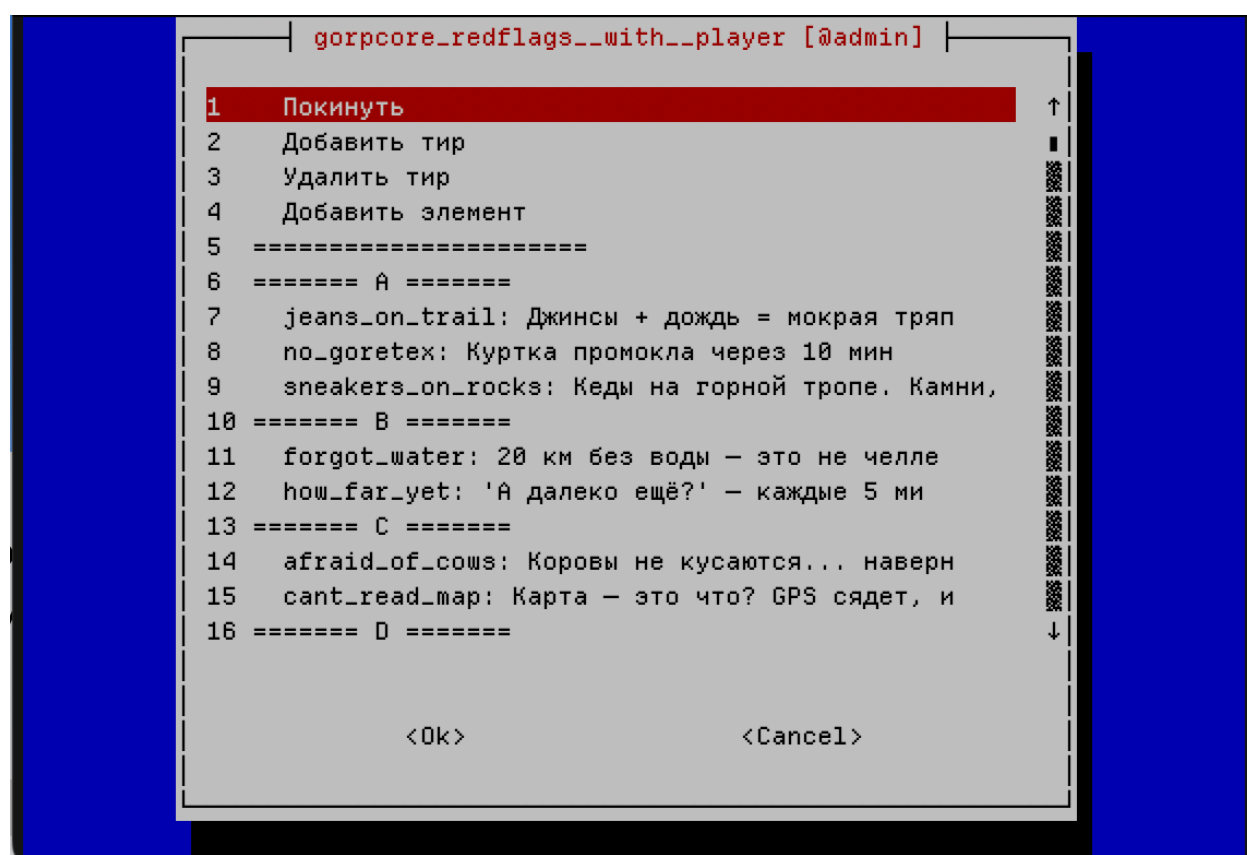
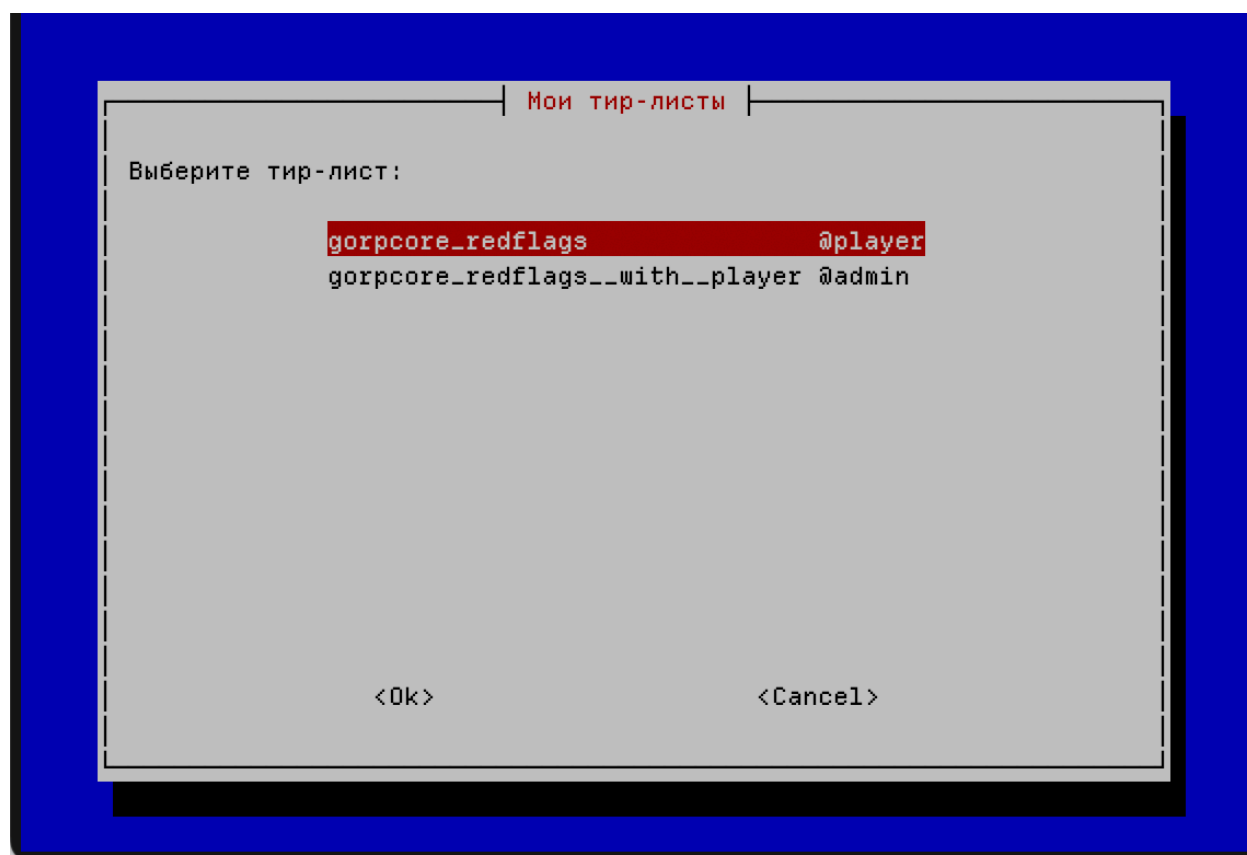
Название нового тир-листа (snake_case):

<Ok> <Cancel>

РЕД-ФЛАГ: тир-листы

Тир-лист 'gorpcore_redflags' создан.

<Ok>



РЕД-ФЛАГ: тир-листы

Вы покинули тир-лист.

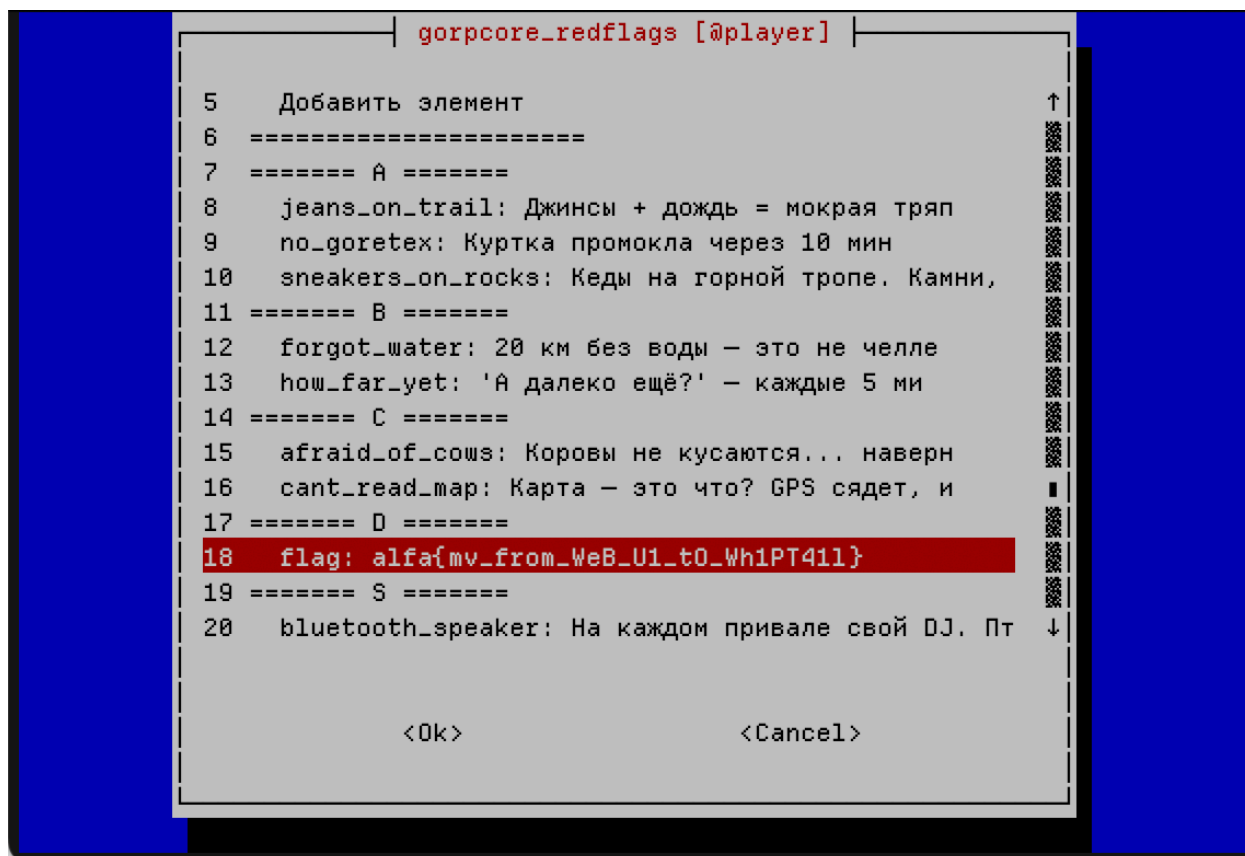
<Ok>

gorpcore_redflags [@player]

- 1 Переименовать тир-лист
- 2 Удалить тир-лист
- 3 Добавить тир
- 4 Удалить тир
- 5 Добавить элемент
- 6 =====
- 7 ===== A =====
- 8 jeans_on_trail: Джинсы + дождь = мокрая тряп
- 9 no_goretex: Куртка промокла через 10 мин
- 10 sneakers_on_rocks: Кеды на горной тропе. Камни,
- 11 ===== B =====
- 12 forgot_water: 20 км без воды — это не челле
- 13 how_far_yet: 'А далеко ещё?' — каждые 5 ми
- 14 ===== C =====
- 15 afraid_of_cows: Коровы не кусаются... наверн
- 16 cant_read_map: Карта — это что? GPS сядет, и

<Ok>

<Cancel>



И да, все вышло как и планировалось, флаг захвачен.